



Gestão de Vulnerabilidades

Mapeamento de Exposição, Priorização de Ativos e Gargalos Operacionais

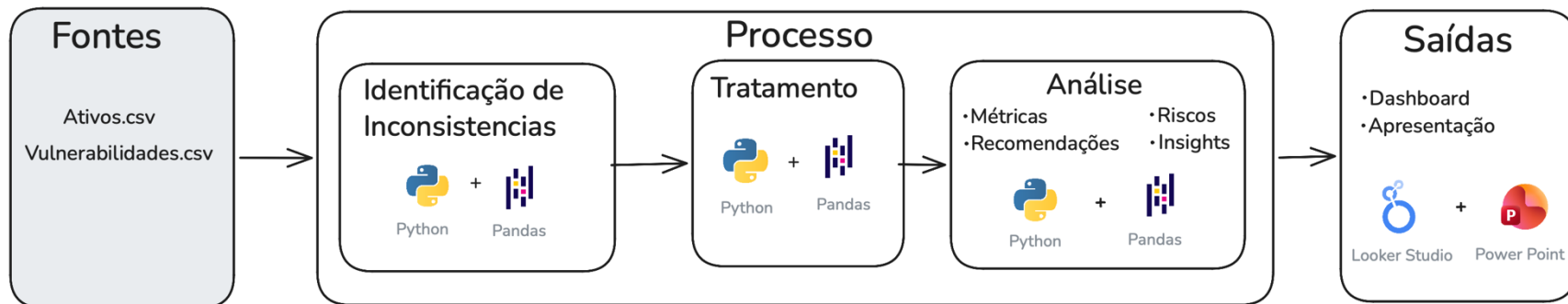
Gustavo Basilio Cancian - GBCMNHR

Vaga ANL Engenharia de Analytics Jr – Cyber Security – 833516 | Outubro de 2026

Estruturação do problema



ETL



1. Qualificar

Mapear os problemas dos dados antes de tratá-los.

2. Tratar

Aplicar regras explícitas, documentadas e sem alterar os dados originais.

3. Analisar

Responder às 4 perguntas da liderança e gerar insights e recomendações.

Arquitetura Medalhão



BRONZE

Dado bruto, original

ativos.csv
vulnerabilidades.csv

Notebook 01 - data_quality:

Diagnóstico das inconsistências,
sem alterar os dados.



SILVER

Dado tratado e tipado

ativos.parquet
vulnerabilidades.parquet

Notebook 02 - data_treatment:

Padroniza, converte datas e
remove dados nulos.

Dados exportados em Parquet
para preservar os tipos.



GOLD

Dado para consumo

vulnerabilidades.csv

Notebook 03 - data_analytics:

Análises, join com ativos e
criação de colunas.

Base utilizada para alimentar o
dashboard.

Qualidade dos dados



78

Datas de abertura inválidas, com formatos alternativos e datas inexistentes (31/02).

72

Registros categóricos com variações: 63 em severidade, 7 em criticidade, 2 em origem.

5

Vulnerabilidades ligadas ao ativo A9999, que não existe na base de ativos.

2

Vulnerabilidades corrigidas com data anterior à data de abertura.

26

Vulnerabilidades sem severidade.

6

Ativos incompletos: 4 sem criticidade e 2 sem ambiente.

Dados validados sem problemas: IDs duplicados, CVSS fora de 0–10, datas de correção inválidas e coerência entre status e data de correção.

Problemas e a decisões tomadas



Problema	Decisão
Datas de abertura inválidas (78)	56 datas foram recuperadas reconhecendo os formatos; 22 datas que eram impossíveis de identificar ficaram nulas
Registros categóricos variados	Tudo foi mapeado para um padrão: Crítica, Alta, Média, Baixa
Ativo A9999 inexistente (5)	Vulnerabilidades relacionadas ao ativo foram removidas
Data de correção antes da data de abertura (2)	A data de correção foi alterada para nula e o registro foi mantido
Severidade, criticidade e ambiente ausentes	Foram mantidos nulos, não foi identificado regra de negócio para realizar os registros
Datas salvas como texto	Foram convertidas para o formato de data

Resultado do tratamento e princípios adotados



2.000 → 1.995

Registros de vulnerabilidades
após remover o ativo
inexistente

56 de 78

Datas de abertura
recuperadas (72%)

22

Datas mantidas nulas por
não representarem uma data
válida

Princípios

- Preservar os dados da camada Bronze, todo o tratamento foi feito em cópias
- Não inserir informações sem evidências
- Registrar cada decisão nos notebooks

Resumo executivo



EXPOSIÇÃO

1.013

Vulnerabilidades Pendentes (Aberta + Em tratamento), 51% da base; 502 são Críticas ou Altas

ATIVOS

A0086

Possui 8 vulnerabilidades Críticas/Altas pendentes

PRIORIZAÇÃO

47 dias

De mediana de correção, igual para Críticas (46) e Altas (47)

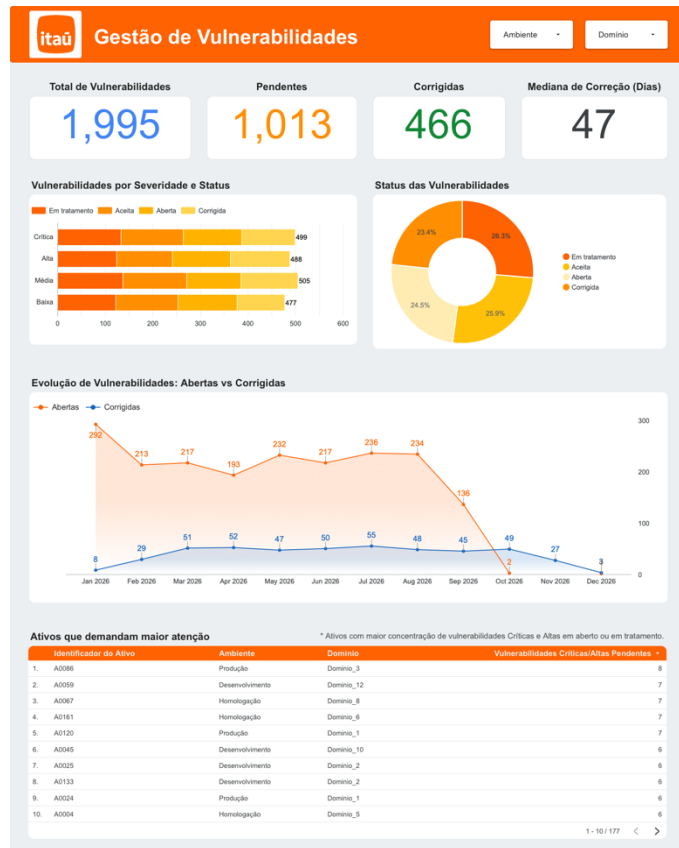
EFETIVIDADE

4x

Mais vulnerabilidades registradas por mês do que corrigidas

*Foi utilizada a mediana ao invés da média para evitar o impacto de valores extremos como um prazo de 230 dias para correção.

Dashboard no Looker Studio



4 KPIs no topo: vulnerabilidades total, pendentes, corrigidas e mediana de correção (dias).

Gráfico de barras em pilhadas para mostrar severidade por status.

Gráfico em donut para visualizar os status das vulnerabilidades.

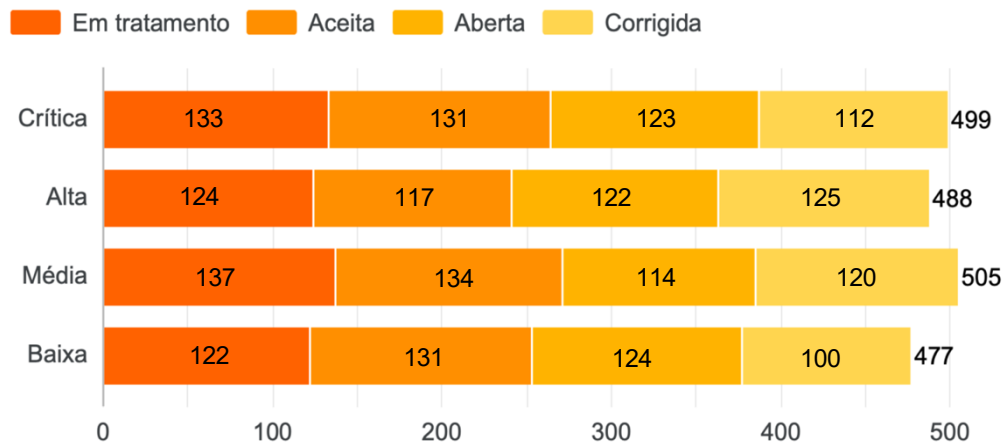
Linhas mensais para visualizar a entrada de vulnerabilidades versus correção, mostrando a efetividade.

Tabela com os ativos de maior atenção e filtros de ambiente e domínio.

Vulnerabilidades por severidade e status

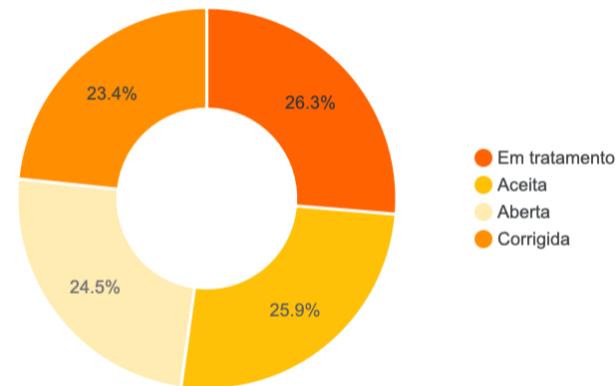


Vulnerabilidades por severidade e status



- **Falta de Priorização:** O gráfico demonstra que o comportamento de tratamento é praticamente o mesmo para uma falha Baixa ou Crítica. Não há priorização clara.

Status das vulnerabilidades



- **Risco Aceito:** Temos 248 vulnerabilidades Críticas ou Altas marcadas como Aceitas.

Ativos prioritários: Críticas e Altas pendentes



	Identificador do Ativo	Ambiente	Dominio	Vulnerabilidades Críticas/Altas Pendentes
1.	A0086	Produção	Dominio_3	8
2.	A0059	Desenvolvi...	Dominio_12	7
3.	A0067	Homologação	Dominio_8	7
4.	A0161	Homologação	Dominio_6	7
5.	A0120	Produção	Dominio_1	7
6.	A0045	Desenvolvi...	Dominio_10	6
7.	A0025	Desenvolvi...	Dominio_2	6
8.	A0133	Desenvolvi...	Dominio_2	6
9.	A0024	Produção	Dominio_1	6

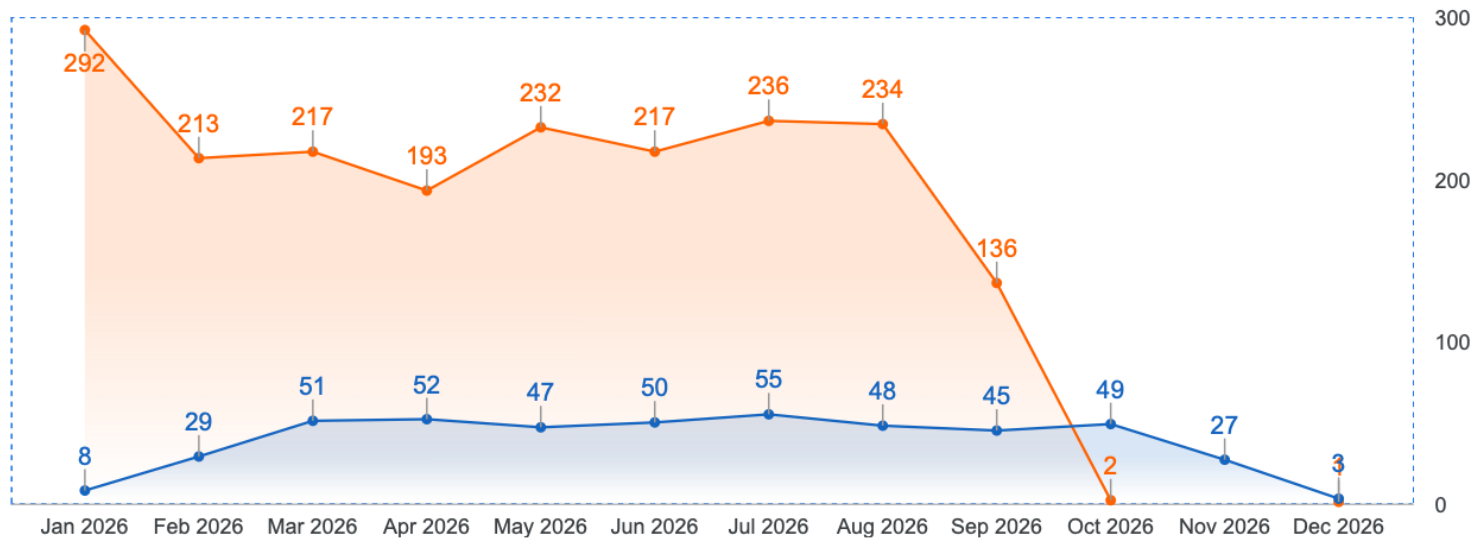
1 - 10 / 177 < >

- **Risco Generalizado:** 88% do ambiente (177 de 200 ativos) possui ao menos uma falha Crítica ou Alta pendente.
- **Alerta na Produção:** o Top 10 mostra uma concentração de vulnerabilidades ativas no ambiente de Produção que sustentam o negócio.

Evolução de Vulnerabilidades



—●— Abertas —●— Corrigidas



- Entrada em torno de 220 por mês de março a agosto

- Entram cerca de 4 vezes mais vulnerabilidades do que são corrigidas.

Perguntas do negócio



Qual é o nível atual de exposição ao risco?

É um nível bem alto, 1.013 vulnerabilidades pendentes (51% da base), sendo 502 Críticas ou Altas.

Quais ativos demandam maior atenção?

O Top 10 liderado pelo ativo A0086 em Produção.

Onde devem ser priorizados os esforços?

Nos 177 ativos com falhas críticas/altas, começando pelos de Produção.

O processo atual é efetivo?

Não, entram 4x mais vulnerabilidades do que as que são corrigidas. Além disso a mediana de correção está estagnado em 47 dias independentemente da severidade.

Recomendações de ações



1

Priorizar vulnerabilidades Críticas e Altas nos ativos mais expostos

502 pendentes; começar por A0086 e A0120.

2

Definir SLAs diferentes por severidade

Hoje todas as severidades levam cerca de 47 dias, vulnerabilidades mais críticas deveriam demorar menos tempo para serem corrigidas.

3

Investigar o tratamento igual para severidades distintas

Rever os riscos aceitos de vulnerabilidades mais críticas.

4

Monitorar entrada, correção e backlog todo mês

Meta: correção próxima ou igual a entrada.

Entregáveis e reprodutibilidade



01_data_quality.ipynb: diagnóstico dos dados



02_data_treatment.ipynb: tratamento e camada Silver



03_data_analytics.ipynb: análises e camada Gold



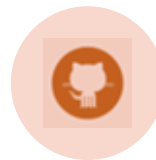
Dashboard no Looker Studio sobre a camada Gold



Esta apresentação executiva



README e requirements.txt para reproduzir o projeto



Projeto no [Github](#)